

Лабораторная работа №4

Безопасность работы удалённых серверов в сети Internet

Часть 1.

Анализ запросов из сети Internet

Теоретические основы

Управление удалёнными серверами может осуществляться с помощью различных протоколов. Одним из наиболее популярных является протокол SSH (Secure Shell – “безопасная оболочка”), который шифрует весь трафик, включая процесс аутентификации. SSH клиенты и SSH серверы доступны для большинства операционных систем. Сам протокол хорошо защищён и получить доступ к передаваемым данным очень сложно.

Существует несколько способов аутентификации с использованием протокола SSH:

- по IP адресу клиента,
- по публичному ключу клиента,
- с помощью логина и пароля.

Программы, поддерживающие протокол SSH, работают следующим образом: при запросе со стороны клиента сервер сообщает ему, какие методы аутентификации он поддерживает и клиент по очереди проверяет их. По умолчанию, клиент вначале пытается пройти процедуру аутентификации своим IP адресом, затем с помощью публичного ключа и, в случае если аутентификация не прошла, передаёт введённые логин и пароль в зашифрованном виде. В случае успешного прохождения аутентификации, вырабатывается сессионный ключ, который позволяет шифровать трафик между клиентом и сервером.

Место хранения логов попыток входа в систему с использованием SSH находятся на файловой системе. Разные операционные системы имеют различные пути хранения журналов SSH серверов. Например, сервер SSH, поставляемый с операционной системой CentOS, сохраняет логи в файлах `/var/log/secure*`. В этих файлах показаны IP адреса, с которых были осуществлены попытки входа в систему, имена пользователей, результат выполнения процедуры аутентификации и другие данные.

Нередки случаи, когда с одного или нескольких IP адресов осуществляется подбор комбинации логина и пароля перебором, по словарю. Для затруднения доступа к серверу с помощью такого рода атак необходимо следовать следующим правилам:

- в случае использования комбинации логина и пароля в качестве аутентификаторов – логин и пароль должен быть сложным (содержать символы

различных алфавитов, строчные и прописные буквы, специальные символы и т. д.),

- запретить суперадминистратору (root) удалённый доступ к системе,
- разрешить доступ через SSH только с определённых IP адресов,
- в случае использования аутентификации по публичному ключу — запретить аутентификацию по логину и паролю.

Среди технических средств, которые могут усложнить несанкционированный доступ в систему и также защитить от других атак, необходимо выделить

- настройка политики безопасности на удалённом сервере (в том числе firewall, ACL и др.),
- виртуальная частная сеть (VPN – Virtual Private Network),
- система обнаружения вторжений (IDS – Intrusion Detection System),
- система предотвращения вторжений (IPS – Intrusion Prevention System).

Также при конфигурации серверных приложений необходимо уделить особое внимание корректной настройке систем безопасности и журналирования. Настройка системы безопасности веб-серверов и систем управления баз данных были рассмотрены в рамках лабораторной работы №2.

В логах различных систем должна содержаться информация о всех попытках доступа к данным системы. Эта информация необходима для анализа активности системы и может быть использована для выявления попыток атаки на систему.

Инструментальные и вспомогательные средства

1. Удалённый сервер, доступный через протокол SSH.
2. SSH клиент (OpenSSH, Putty, WinSCP).

Задание для самостоятельной работы

1. Установить на удалённом сервере веб-сервер и разместить на нём тестовую страницу, доступную из сети Internet.
2. Настроить систему журналирования на веб-сервере.
3. Выполнить анализ данных логов различных подсистем, в том числе SSH, веб-сервера удалённого сервера за несколько дней.
4. Оформить отчёт о проделанной работе.

Отчётность

В качестве результата ожидается:

1. демонстрация работы веб-сервера с тестовой страницей;
2. демонстрация файлов, необходимых для анализа;
3. анализ запросов в различные подсистемы;
4. отчёт о проделанной работе.

Отчёт должен быть оформлен в соответствии с http://www.bsuir.by/m/12_100229_1_80040.pdf.

Отчёт должен содержать следующую информацию.

1. Постановка задачи.
2. Краткое описание веб-сервера.
3. Краткое описание анализируемых файлов: для чего они нужны, что в них содержится и т. д.
4. Анализ запросов из сети на SSH сервер и веб-сервер.
5. Рекомендации улучшения безопасности удалённого сервера.
6. Вывод. В выводе должны быть представлена семантическая и прагматическая составляющие проделанной работы.